FinTrust — AI Threat Modeling Exercise (MITRE ATLAS)

COMPANY: FinTrust (650 employees, fintech)
SYSTEM: FinTrust IDV — face-matching identity-verification ML pipeline. Used during customer onboarding (KYC) to decide whether to admit a new customer to the platform.
DEPLOYMENT: Public mobile-app endpoint. Customer uploads a selfie + a photo of their government-issued ID. The face-match model returns a similarity score; a downstream rules engine combines that score with document-OCR signals to make the KYC admit / decline / manual-review decision.
REGULATORY CONTEXT: GDPR (biometric data — Art. 9 special-category data); EU AI Act (biometric identification — High-Risk Annex III §1); US BSA/AML (KYC obligations); state biometric privacy laws (BIPA-style).
RECENT TRIGGER: A competitor's KYC system was bypassed last quarter using printed-photo presentation attacks. The AI review board has put FinTrust IDV's launch on hold until a threat model is complete.

ARCHITECTURE (one-line per node):

1. End user → mobile app (camera capture + ID upload).
2. App → FinTrust API gateway (TLS, mobile-app attestation, public endpoint).
3. Gateway → Image preprocessing service (face crop, ID document straightening).
4. Preprocessor → Face-match ML model (in-house, fine-tuned ResNet-style embedder + cosine similarity).
5. Model → KYC rules engine (combines similarity score, OCR signals, sanctions hit).
6. Rules engine → KYC decision (admit / decline / manual review).
7. Monthly retrain pipeline pulls new ID-photo pairs from production queue (with consent flag).

YOUR TASK:

Lead the threat-modeling session for FinTrust IDV ahead of launch. Two ATLAS TTPs are scoped end-to-end as worked examples; you scope 3 more (their IDs are pre-selected on the Threat Model sheet; the ATLAS TTP Reference sheet has the full candidate list), then produce a 1-page board-facing summary on the Board Brief sheet.

COLOR LEGEND:

Blue Header — Sheet / column headers
Green — Scenario information
Light Blue — Pre-filled context / worked example rows
Pink — Student work areas — fill these cells
Yellow — Reference / rubric (read-only)

TTP ID	TTP Name	ATLAS Tactic
AML.T0006	Active Scanning	Reconnaissance
AML.T0040	AI Model Inference API Access	AI Model Access
AML.T0015	Evade AI Model — Deepfake / Generative-Liveness Bypass	Defense Evasion / Initial Access
AML.T0024	Exfiltration via AI Inference API	Exfiltration
AML.T0020	Poison Training Data	Persistence / Resource Development

Architecture Scoping	Likelihood (1-5)	Impact (1-5)
The mobile-app endpoint is publicly reachable; an attacker can scrape app binaries from the Play Store / App Store, extract the API contract, and probe the gateway to map FinTrust's IDV surface before any other technique is attempted.	5	1
The face-match endpoint is exposed via the mobile-app gateway; once an attacker has passed app attestation, they can query the model with arbitrary image pairs and observe similarity scores, providing the substrate for downstream evasion or extraction attacks.	4	2
The mobile-app face-match endpoint accepts user-uploaded selfies. An attacker uses a real-time generative AI face-swap filter (deepfake) to bypass the liveness check, injecting a synthetic identity to pass KYC, directly mirroring the recent competitor incident	4	5
An attacker uses the public face-match API to query thousands of image pairs, observing similarity scores to reverse-engineer a surrogate of the face-match embedder, or to recover enrolled biometrics via membership-inference attacks.	3	4
An attacker pushes a coordinated batch of poisoned biometric samples or synthetic identities through the production onboarding queue, which are then ingested into the monthly retrain pipeline, causing the model to learn a targeted blind spot that allows future KYC bypasses at scale.	2	5

Risk Score	Risk Level	Control Family
5	Medium	Gateway Controls
8	Medium	Gateway Controls + Behavioral Monitoring
20	Critical	Presentation Attack Detection (PAD) & Liveness Controls
12	High	API Security & Behavioral Monitoring
10	High	Data Pipeline & Model Integrity Controls

Named Controls	Owner
1) Mobile-app attestation (Play Integrity / App Attest) at the gateway. 2) WAF rules on anomalous probe patterns. 3) Honeypot endpoints to detect mapping behavior.	Platform Security
1) Per-account and per-IP rate limits at the gateway. 2) Anomaly detection on query-volume per session. 3) Score-quantization (return banded scores rather than raw cosine values).	Platform Security
1) Active challenge-response liveness (e.g., "turn head", "read numbers"). 2) 3D depth-sensing (TrueDepth camera APIs). 3) On-device injection-attack detection (detecting virtual cameras).	Computer Vision
1) Strict score quantization (returning "Match/No Match" instead of raw cosine similarity scores). 2) Hard daily query caps per account/IP. 3) Extraction-pattern anomaly detection on API volume.	Platform Security / MLOps Team
1) Outlier filtering and anomaly detection on the training data ingestion path. 2) Adversarial canary test sets evaluated before model promotion. 3) Human review of edge-case data before adding it to the retrain queue.	Data Science / MLOps Team

Status
Open
Open
Open
Open
Open

BOARD BRIEF — FinTrust IDV — pre-launch board brief	
System u	FinTrust IDV: face-matching identity-verification ML pipeline on a public mobile-app endpoint; in-h model; downstream KYC rules engine; monthly retrain pulling from production with consent flag.

A. TOP 3 TTPS (ranked by Risk Score; tie-break by Impact)			
Rank	**TTP ID**	**TTP Name**	**Risk Score**
1	AML.T0015	Evade AI Model — Deepfake / Generative-Liveness Bypass	20
2	AML.T0024	Exfiltration via AI Inference API	12
3	AML.T0020	Poison Training Data	10

B. RECOMMENDED CONTROLS PER TOP TTP	
TTP	**Recommended controls + residual risk after controls**
AML.T0015 — Deepfake / Generative-Liveness Bypass	Implement active challenge-response liveness and 3D depth-sensing. Residual ris sophisticated, real-time 3D-printed masks or advanced deepfakes may still bypas though at a much higher cost to the attacker.
AML.T0024 — Exfiltration via AI Inference API	Apply strict score quantization (Match/No Match) and hard daily query caps. Resi Attackers using distributed IP networks (botnets) may still extract enough data ov to build a weak surrogate model.
AML.T0020 — Poison Training Data	Deploy outlier filtering on the ingestion path and adversarial canary sets before n promotion. Residual risk: A slow, coordinated poisoning campaign by a patient at drift the model slightly without triggering automated anomaly thresholds.

C. RECOMMENDATION TO THE AI REVIEW BOARD	
Decision:	**[Your response here — pick exactly one: Launch / Conditional Launch / No-Go.]**

Rationale	FinTrust IDV faces a Critical deepfake bypass risk (Score: 20). While the overall risk posture is mana proposed mitigation families, launching without active liveness detection invites catastrophic finan regulatory damage. We recommend a Conditional Launch: the system may go live ONLY after activ response liveness and strict API score-quantization are deployed and validated by a red-team exerc
Prepared	Muhammad Safyan— AI Security Architect
Companic	Threat Model sheet (this workbook)
Framewo	MITRE ATLAS (primary); STRIDE-ML / LINDDUN (design-time cross-check)

ouse face-match

Risk Level
Critical
High
High

k: Highly s the check,	
idual risk: ver a long period	
nodel tacker could	

geable with our
cial and
e challenge-
:ise.

1
2
3
4
5

1
2
3
4
5

CRITICAL
HIGH
MEDIUM
LOW

LIKELIHOOD SCALE (1–5)
Rare — extremely unlikely to occur (< 5%) given current architecture / threat landscape
Unlikely — low probability (5–25%); requires sophisticated attacker or unusual circumstances
Possible — moderate probability (25–50%); plausible against a motivated attacker
Likely — high probability (50–75%); within 12 months given the public surface
Almost Certain — very likely (> 75%); already documented against comparable systems

IMPACT SCALE (1–5)
Negligible — minimal organizational or user impact; recoverable with internal handling
Minor — limited user impact; some manual response cost; no regulatory exposure
Moderate — affects a measurable user subset; possible regulatory inquiry; brand exposure
Major — broad user impact; clear regulatory exposure; material financial loss
Catastrophic — systemic failure; large-scale user harm; regulatory action; existential brand risk

RISK LEVEL THRESHOLDS (Risk Score = Likelihood × Impact)
≥ 15 — Immediate executive attention; block launch until mitigated
10–14 — Prioritize mitigation in current sprint; revisit at AI review board
5–9 — Schedule mitigation within 90 days; track in risk register
< 5 — Monitor; mitigate as resources allow

TTP ID	TTP Name
AML.T0000	Search Victim's Publicly Available Research Materials
AML.T0006	Active Scanning
AML.T0015	Evade AI Model
AML.T0018	Backdoor AI Model
AML.T0020	Poison Training Data
AML.T0024	Exfiltration via AI Inference API
AML.T0029	Denial of AI Service
AML.T0040	AI Model Inference API Access
AML.T0043	Craft Adversarial Data
AML.T0044	Full AI Model Access
AML.T0048	External Harms
AML.T0051	LLM Prompt Injection
AML.T0057	LLM Data Leakage

ATLAS Tactic
Reconnaissance
Reconnaissance
Defense Evasion / Initial Access
Persistence
Persistence / Resource Development
Exfiltration
Impact
AI Model Access
AI Attack Staging
AI Model Access
Impact
Initial Access
Exfiltration

One-Line Description
Adversary scans public papers, model cards, or repos to learn the target's model architecture, training data, or guardrails.
Adversary probes the AI system's API surface — endpoints, rate limits, auth — to map the attack surface.
Adversary crafts inputs designed to be misclassified by the model (adversarial / presentation / prompt-evasion attacks).
Adversary embeds a trigger into a model (during training or fine-tune) so that specific inputs produce attacker-chosen outputs.
Adversary contaminates training or retrain data to degrade performance, induce bias, or plant a backdoor.
Adversary issues large numbers of queries to reconstruct a surrogate model, recover training data, or infer membership.
Adversary degrades or disables a model — through resource exhaustion, query flooding, or amplification — to deny service.
Adversary obtains the ability to query the deployed model and observe outputs (precondition for many other techniques).
Adversary generates adversarial examples (white-box, black-box, or transfer) targeting the deployed model.
Adversary obtains direct access to model weights, enabling any white-box attack.
Adversary leverages model output to cause real-world harm — financial loss, reputational damage, user harm, regulatory breach.
Adversary inserts instructions into input that an LLM treats as authoritative, overriding system prompts or invoking attacker-chosen tool calls.
Adversary induces an LLM to emit secrets or training data (system prompt, retrieved context, PII) through crafted prompts.

Control Family
Input Filtering
Output Moderation
Gateway Controls
Behavioral Monitoring
Tool-Use Guardrails
Training-Pipeline Integrity
Financial Controls
Logging & Audit

What it covers
Pre-model controls applied to inbound input — prompt-injection classifiers, adversarial-input detectors, liveness checks, input schema validation.
Post-model controls applied to model output — toxicity / PII filters, jailbreak detectors, system-prompt-leak detectors, response gating.
Network-layer controls — authentication, per-IP / per-account rate limits, mobile-app attestation, WAF, bot detection, CAPTCHA.
Telemetry-driven controls — anomaly detection on query patterns, session-level outlier detection, drift detection, abuse-pattern alerting.
Controls on agent tool calls — allowlists, server-side parameter validation, hard caps, mandatory human-in-the-loop above thresholds.
Controls on model training / retrain — provenance tracking, outlier filtering, hold-out adversarial test sets, model-promotion gates.
Controls that bound financial blast radius — transaction caps, daily aggregate limits, mandatory dual-control, revocation paths.
Reproducible logs of model inputs, outputs, prompts, retrieved context, and tool calls for investigation and regulator response.

Topic
AML.T0048 sub-techniques
AML.T0018 parent tactics
AML.T0000 official name
ML → AI naming evolution
Authoritative reference

Specification detail
ATLAS structures External Harms (AML.T0048) into sub-techniques. The financial-loss case is captured precisely by AML.T0048.000 "Financial Harm" — ATLAS uses the term "Financial Harm" in the catalog. ATLAS lists Backdoor AI Model under both "Persistence" and "AI Attack Staging" tactics, depending on whether the backdoor is staged before deployment or seeded post-deployment. The catalog name includes "for": "Search for Victim's Publicly Available Research Materials." ATLAS has been renaming the prefix from "ML" to "AI" in some technique names (e.g., AML.T0040 is "AI Model Inference API Access" in current revisions). Technique IDs are the stable canonical reference; treat the ID as authoritative when the name on the live catalog differs from the workbook label. See https://atlas.mitre.org/ and per-technique pages (e.g., https://atlas.mitre.org/techniques/AML.T0048/).